Задание 2
Локальное сканирование 3
Проблема локального запуска 3
Запуск в контейнере 4
Сканирование через Docker 6
GitLab CI 13
VMS. Опциональная часть 18
Дополнительная информация 25

Задание

Задача:

Для уязвимого проекта django.nv:

DAST:

1. Запустить проект локально

2. Протестировать работу OWASP Zap - скачать докер-образ инструмента, запустить сканирование, получить отчет в формате json, xml

3. Встроить OWASP Zap с генерацией артефакта формате xml (stage prod). job не должна останавливать работу pipeline, отчеты, полученные в ходе job, должны быть сохранены в виде артефакта работы.

ДЗ VMS (опционально):

1. Развернуть DefectDojo (https://defectdojo.com, https://github.com/DefectDojo/django-DefectDojo), изучить документацию и его api

2. На основе показанного в вебинаре скрипта написать свой скрипт по загрузку отчетов в Dojo

3. Интегрировать автоматическую выгрузку отчетов из CI/CD в DefectDojo для SCA, SAST и DAST в соответствующие job, написанные ранее в ДЗ

Формат выполнения: отчет в формате PDF, который содержит скриншоты команд и результатов работы при запуске в виде докер-образа и в CI/CD, а также финальный код итогового pipeline. Если сделали VMS-часть, то скриншоты с выгрузкой распаршенных отчетов для каждого из инструментов.

Локальное сканирование

Проблема локального запуска

Ввиду текущих проблем версии Python требуемого для запуска проекта и установленной версии локально возникают конфликты принято решение запустить проект Django.Nv в контейнером окружении.

- Django 1.8.3 — версия указана в requirements.txt и до выхода Python 3.4 или 3.5.
- Python 3.13 (в моей Anaconda) — это свежая версия от 2024 года.

```
(base) sapman@Mac-mini-sapman django.nV %
(base) sapman@Mac-mini-sapman django.nV % pip3 install -r requirements.txt
Collecting Django==1.8.3 (from -r requirements.txt (line 1))
  Downloading Django-1.8.3-py2.py3-none-any.whl.metadata (1.3 kB)
Downloading Django-1.8.3-py2.py3-none-any.whl (6.2 MB)
   ━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━ 6.2/6.2 MB 5.6 MB/s eta 0:00:00
Installing collected packages: Django
Successfully installed Django-1.8.3
(base) sapman@Mac-mini-sapman django.nV %
(base) sapman@Mac-mini-sapman django.nV % python3 manage.py migrate
Traceback (most recent call last):
  File "/Users/sapman/Downloads/DevSecOps - ВШЭ/GIT/django.nV/manage.py", line 23, in <module>
    from django.core.management import execute_from_command_line
  File "/opt/anaconda3/lib/python3.13/site-packages/django/core/management/__init__.py", line 10, in <module>
    from django.apps import apps
  File "/opt/anaconda3/lib/python3.13/site-packages/django/apps/__init__.py", line 1, in <module>
    from .config import AppConfig   # NOQA
    ^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^
  File "/opt/anaconda3/lib/python3.13/site-packages/django/apps/config.py", line 4, in <module>
    from django.core.exceptions import AppRegistryNotReady, ImproperlyConfigured
  File "/opt/anaconda3/lib/python3.13/site-packages/django/core/exceptions.py", line 5, in <module>
    from django.utils.encoding import force_text
  File "/opt/anaconda3/lib/python3.13/site-packages/django/utils/encoding.py", line 10, in <module>
    from django.utils.functional import Promise
  File "/opt/anaconda3/lib/python3.13/site-packages/django/utils/functional.py", line 9, in <module>
    from django.utils.six.moves import copyreg
ModuleNotFoundError: No module named 'django.utils.six.moves'
(base) sapman@Mac-mini-sapman django.nV %
```

```Plaintext

 django.nV % pip3 install -r requirements.txt

Collecting Django==1.8.3 (from -r requirements.txt (line 1))

  Downloading Django-1.8.3-py2.py3-none-any.whl.metadata (1.3 kB)

Downloading Django-1.8.3-py2.py3-none-any.whl (6.2 MB)

   ━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━ 6.2/6.2 MB 5.6 MB/s eta 0:00:00

Installing collected packages: Django

Successfully installed Django-1.8.3

django.nV %

django.nV % python3 manage.py migrate

Traceback (most recent call last):

  File "/Users/user/Downloads/django.nV/manage.py", line 23, in <module>

    from django.core.management import execute_from_command_line
```

```
  File "/opt/anaconda3/lib/python3.13/site-packages/django/core/management/__init__.py", line 10, in <module>
    from django.apps import apps
  File "/opt/anaconda3/lib/python3.13/site-packages/django/apps/__init__.py", line 1, in <module>
    from .config import AppConfig   # NOQA
    ^^^^^^^^^^^^^^^^^^^^^^^^^^^^^
  File "/opt/anaconda3/lib/python3.13/site-packages/django/apps/config.py", line 4, in <module>
    from django.core.exceptions import AppRegistryNotReady, ImproperlyConfigured
  File "/opt/anaconda3/lib/python3.13/site-packages/django/core/exceptions.py", line 5, in <module>
    from django.utils.encoding import force_text
  File "/opt/anaconda3/lib/python3.13/site-packages/django/utils/encoding.py", line 10, in <module>
    from django.utils.functional import Promise
  File "/opt/anaconda3/lib/python3.13/site-packages/django/utils/functional.py", line 9, in <module>
    from django.utils.six.moves import copyreg
ModuleNotFoundError: No module named 'django.utils.six.moves'
django.nV %
```

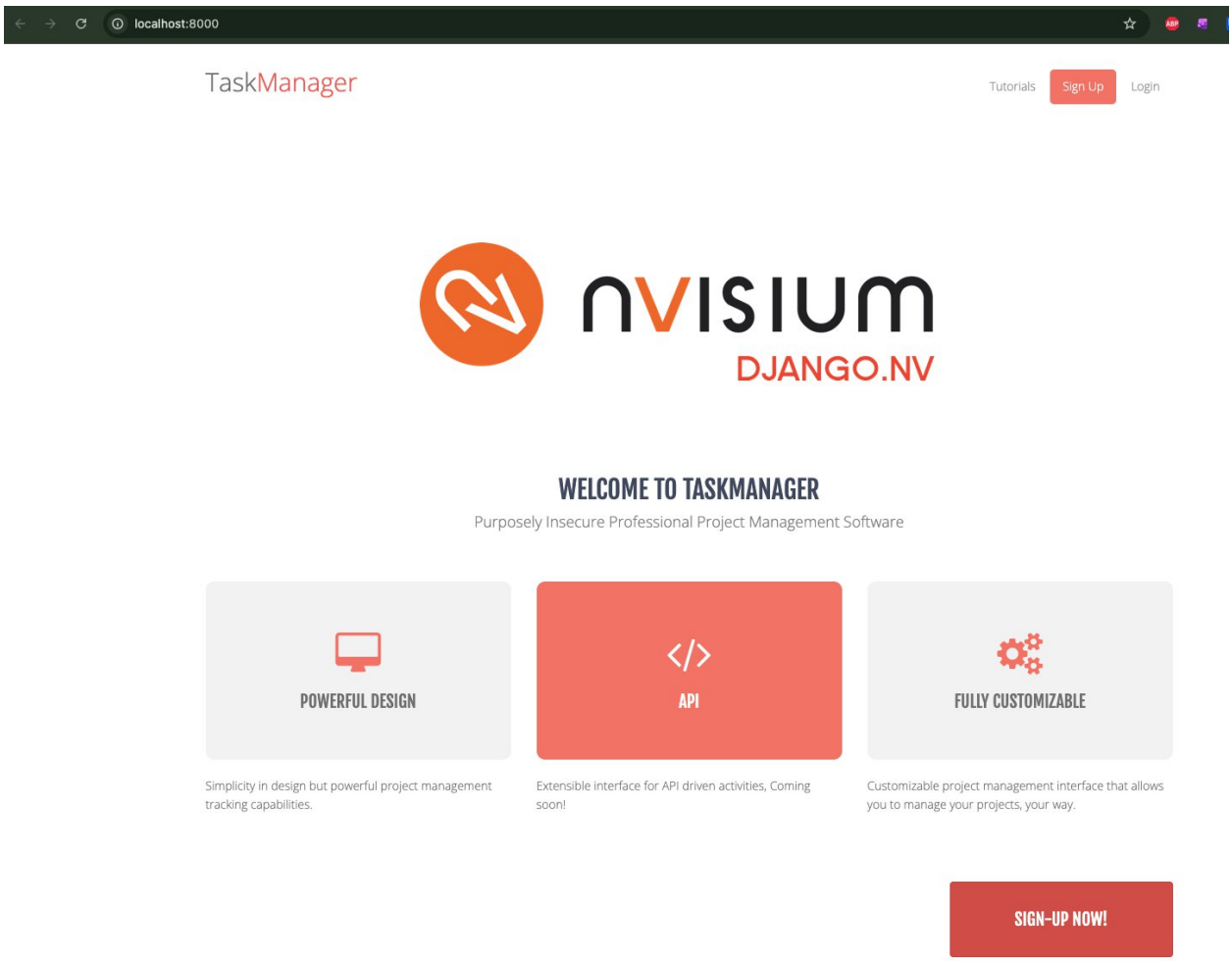
Запуск в контейнере

Команда для запуска

```bash
docker run --name django-nv-app -p 8000:8000 \
-v "$(pwd):/app" -w /app \
python:3.6-slim \
sh -c "pip install -r requirements.txt && python manage.py migrate && python manage.py runserver 0.0.0.0:8000"
```

```
(base) sapman@Mac-mini-sapman django.nV %
(base) sapman@Mac-mini-sapman django.nV % docker run --name django-nv-app -p 8000:8000 -v "$(pwd):/app" -w /app python:3.6-slim sh -c "pip install -r requirements.txt && python manage.py
 migrate && python manage.py runserver 0.0.0.0:8000"
Unable to find image 'python:3.6-slim' locally
3.6-slim: Pulling from library/python
927a35006d93: Pull complete
87a44f46fb9c: Pull complete
9a9d4284ceea: Pull complete
9ff0b03a8896: Pull complete
20c700732698: Pull complete
Digest: sha256:2cfebc27956e6a55f78606864d91fe527696f9e32a724e6f9702b5f9602d0474
Status: Downloaded newer image for python:3.6-slim
Collecting Django==1.8.3
  Downloading Django-1.8.3-py2.py3-none-any.whl (6.2 MB)
Installing collected packages: Django
Successfully installed Django-1.8.3
WARNING: Running pip as the 'root' user can result in broken permissions and conflicting behaviour with the system package manager. It is recommended to use a virtual environment instead
: https://pip.pypa.io/warnings/venv
WARNING: You are using pip version 21.2.4; however, version 21.3.1 is available.
You should consider upgrading via the '/usr/local/bin/python -m pip install --upgrade pip' command.
Operations to perform:
  Synchronize unmigrated apps: messages, staticfiles
  Apply all migrations: admin, auth, contenttypes, taskManager
Synchronizing apps without migrations:
  Creating tables...
    Running deferred SQL...
  Installing custom SQL...
Running migrations:
  Rendering model states... DONE
  Applying contenttypes.0001_initial... OK
  Applying auth.0001_initial... OK
  Applying admin.0001_initial... OK
  Applying contenttypes.0002_remove_content_type_name... OK
  Applying auth.0002_alter_permission_name_max_length... OK
  Applying auth.0003_alter_user_email_max_length... OK
  Applying auth.0004_alter_user_username_opts... OK
  Applying auth.0005_alter_user_last_login_null... OK
  Applying auth.0006_require_contenttypes_0002... OK
  Applying taskManager.0001_initial... OK
  Applying taskManager.0002_auto_20141010_2102... OK
  Applying taskManager.0003_auto_20141028_1913... OK
  Applying taskManager.0004_task_completed... OK
  Applying taskManager.0005_project_user... OK
  Applying taskManager.0006_auto_20141209_0644... OK
  Applying taskManager.0007_delete_assignproject... OK
  Applying taskManager.0008_project_users_assinged... OK
  Applying taskManager.0009_task_users_assinged... OK
  Applying taskManager.0010_auto_20141211_1914... OK
  Applying taskManager.0011_notes_user... OK
  Applying taskManager.0012_notes_image_url... OK
  Applying taskManager.0013_userprofile... OK
  Applying taskManager.0014_auto_20141224_2059... OK
  Applying taskManager.0015_auto_20141224_2123... OK
  Applying taskManager.0016_auto_20141227_0256... OK
  Applying taskManager.0017_auto_20141227_0427... OK
  Applying taskManager.0018_task_title... OK
  Applying taskManager.0019_notes_title... OK
  Applying taskManager.0020_auto_20150316_0621... OK
  Applying taskManager.0021_task_due_date... OK
  Applying taskManager.0022_auto_20150322_2350... OK
  Applying taskManager.0023_auto_20150324_1650... OK
  Applying taskManager.0024_auto_20150324_1737... OK
  Applying taskManager.0025_auto_20150324_2340... OK
  Applying taskManager.0026_auto_20150324_2342... OK
  Applying taskManager.0027_auto_20150324_2346... OK
  Applying taskManager.0028_auto_20150325_0010... OK
  Applying taskManager.0029_auto_20150325_0015... OK
  Applying taskManager.0030_auto_20150325_0023... OK
  Applying taskManager.0031_auto_20150325_0112... OK
  Applying taskManager.0032_auto_20150325_0155... OK
  Applying taskManager.0033_auto_20150325_0159... OK
  Applying taskManager.0034_auto_20150921_1829... OK
  Applying taskManager.0035_auto_20150921_2024... OK
  Applying taskManager.0036_auto_20150921_2024... OK
  Applying taskManager.0037_auto_20150921_2025... OK
  Applying taskManager.0038_auto_20150921_2027... OK
```

Проверка подключения по http://localhost:8000/



Сканирование через Docker

Запуск образа OWASP Zap

Версия для arm-процессора (Apple Silicone)

```bash
docker run --rm -u root -v "$(pwd):/zap/wrk/:rw" \
-t zaproxy/zap-stable zap-baseline.py \
-t http://host.docker.internal:8000 \
-J zap-report.json -x zap-report.xml
```

Вывод лога запуска

```Plaintext
```

django.nV % docker run --rm -u root -v "$(pwd):/zap/wrk/:rw" -t zaproxy/zap-stable zap-baseline.py -t http://host.docker.internal:8000 -J zap-report.json -x zap-report.xml

Unable to find image 'zaproxy/zap-stable:latest' locally

latest: Pulling from zaproxy/zap-stable

1dbbb2db815c: Pull complete

c8d09c37986b: Pull complete

5d9591fe0849: Pull complete

1f5d3138364a: Pull complete

c7bcd7545dc2: Pull complete

6cc5f8166a8f: Pull complete

4f4fb700ef54: Pull complete

e039cda8c112: Pull complete

0631a84110d1: Pull complete

c1f54caee7ee: Pull complete

546e225bbd21: Pull complete

6e84b9e21399: Pull complete

79930899c92e: Pull complete

90d22e91690c: Pull complete

d5e29918fb24: Pull complete

22f5576fdcda: Pull complete

69d986feefc5: Pull complete

fd9f6600bc27: Pull complete

c4c056a77532: Pull complete

4b362275d971: Pull complete

Digest: sha256:707fc6b9fd8327ba48bb7b49d0c5732c179b045dab9c99f8b95410627dff4a00

Status: Downloaded newer image for zaproxy/zap-stable:latest

Using the Automation Framework

Total of 63 URLs

PASS: In Page Banner Information Leak [10009]

PASS: Cookie Without Secure Flag [10011]

PASS: Re-examine Cache-control Directives [10015]

PASS: Content-Type Header Missing [10019]

PASS: Anti-clickjacking Header [10020]

PASS: Information Disclosure - Debug Error Messages [10023]

PASS: Information Disclosure - Sensitive Information in URL [10024]

PASS: Information Disclosure - Sensitive Information in HTTP Referrer Header [10025]

PASS: HTTP Parameter Override [10026]

PASS: Off-site Redirect [10028]

PASS: Cookie Poisoning [10029]

PASS: User Controllable Charset [10030]

PASS: User Controllable HTML Element Attribute (Potential XSS) [10031]

PASS: Viewstate [10032]

PASS: Directory Browsing [10033]

PASS: Heartbleed OpenSSL Vulnerability (Indicative) [10034]

PASS: Strict-Transport-Security Header [10035]

PASS: Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s) [10037]

PASS: X-Backend-Server Header Information Leak [10039]

PASS: Secure Pages Include Mixed Content [10040]

PASS: HTTP to HTTPS Insecure Transition in Form Post [10041]

PASS: HTTPS to HTTP Insecure Transition in Form Post [10042]

PASS: User Controllable JavaScript Event (XSS) [10043]

PASS: Big Redirect Detected (Potential Sensitive Information Leak) [10044]

PASS: Retrieved from Cache [10050]

PASS: X-ChromeLogger-Data (XCOLD) Header Information Leak [10052]

PASS: CSP [10055]

PASS: X-Debug-Token Information Leak [10056]

PASS: Username Hash Found [10057]

PASS: X-AspNet-Version Response Header [10061]

PASS: PII Disclosure [10062]

PASS: Timestamp Disclosure [10096]

PASS: Hash Disclosure [10097]

PASS: Cross-Domain Misconfiguration [10098]

PASS: Weak Authentication Method [10105]

PASS: Reverse Tabnabbing [10108]

PASS: Dangerous JS Functions [10110]

PASS: Verification Request Identified [10113]

PASS: Script Served From Malicious Domain (polyfill) [10115]

PASS: ZAP is Out of Date [10116]

PASS: Session ID in URL Rewrite [3]

PASS: Script Passive Scan Rules [50001]

PASS: Stats Passive Scan Rule [50003]

PASS: Insecure JSF ViewState [90001]

PASS: Java Serialization Object [90002]

PASS: Charset Mismatch [90011]

PASS: WSDL File Detection [90030]

PASS: Loosely Scoped Cookie [90033]

WARN-NEW: Vulnerable JS Library [10003] x 2

http://host.docker.internal:8000/static/taskManager/js/bootstrap.js (200 OK)

http://host.docker.internal:8000/static/taskManager/js/jquery-1.8.3.min.js (200 OK)

WARN-NEW: Cookie No HttpOnly Flag [10010] x 2

http://host.docker.internal:8000/taskManager/login/ (200 OK)

http://host.docker.internal:8000/taskManager/register/ (200 OK)

WARN-NEW: Cross-Domain JavaScript Source File Inclusion [10017] x 5

http://host.docker.internal:8000 (200 OK)

http://host.docker.internal:8000/ (200 OK)

http://host.docker.internal:8000/taskManager/ (200 OK)

http://host.docker.internal:8000/taskManager/register/ (200 OK)

http://host.docker.internal:8000/taskManager/tutorials/ (200 OK)

WARN-NEW: X-Content-Type-Options Header Missing [10021] x 5

http://host.docker.internal:8000 (200 OK)

http://host.docker.internal:8000/ (200 OK)

http://host.docker.internal:8000/static/taskManager/css/bootstrap.min.css (200 OK)

http://host.docker.internal:8000/static/taskManager/css/font-awesome.css (200 OK)

http://host.docker.internal:8000/taskManager/tutorials/ (200 OK)

WARN-NEW: Information Disclosure - Suspicious Comments [10027] x 12

http://host.docker.internal:8000/taskManager/register/ (200 OK)

http://host.docker.internal:8000/taskManager/tutorials/ (200 OK)

http://host.docker.internal:8000/taskManager/tutorials/access/ (200 OK)

http://host.docker.internal:8000/taskManager/tutorials/brokenauth/ (200 OK)

http://host.docker.internal:8000/taskManager/tutorials/components/ (200 OK)

WARN-NEW: Server Leaks Version Information via "Server" HTTP Response Header Field [10036] x 5

http://host.docker.internal:8000 (200 OK)

http://host.docker.internal:8000/ (200 OK)

http://host.docker.internal:8000/robots.txt (404 Not Found)

http://host.docker.internal:8000/sitemap.xml (404 Not Found)

http://host.docker.internal:8000/taskManager/register (301 Moved Permanently)

WARN-NEW: Content Security Policy (CSP) Header Not Set [10038] x 2

http://host.docker.internal:8000 (200 OK)

http://host.docker.internal:8000/ (200 OK)

WARN-NEW: Storable and Cacheable Content [10049] x 5

http://host.docker.internal:8000 (200 OK)

http://host.docker.internal:8000/robots.txt (404 Not Found)

http://host.docker.internal:8000/sitemap.xml (404 Not Found)

http://host.docker.internal:8000/static/taskManager/css/bootstrap.min.css (200 OK)

http://host.docker.internal:8000/taskManager/tutorials/ (200 OK)

WARN-NEW: Cookie without SameSite Attribute [10054] x 2

http://host.docker.internal:8000/taskManager/login/ (200 OK)

http://host.docker.internal:8000/taskManager/register/ (200 OK)

WARN-NEW: Permissions Policy Header Not Set [10063] x 5

http://host.docker.internal:8000 (200 OK)

http://host.docker.internal:8000/ (200 OK)

http://host.docker.internal:8000/robots.txt (404 Not Found)

http://host.docker.internal:8000/sitemap.xml (404 Not Found)

http://host.docker.internal:8000/taskManager/tutorials/ (200 OK)

WARN-NEW: Source Code Disclosure - SQL [10099] x 1

http://host.docker.internal:8000/taskManager/tutorials/injection/ (200 OK)

WARN-NEW: Modern Web Application [10109] x 1

http://host.docker.internal:8000/taskManager/forgot_password/ (500 Internal Server Error)

WARN-NEW: Authentication Request Identified [10111] x 1

http://host.docker.internal:8000/taskManager/login/ (403 Forbidden)

WARN-NEW: Session Management Response Identified [10112] x 2

http://host.docker.internal:8000/taskManager/login/ (200 OK)

http://host.docker.internal:8000/taskManager/register/ (200 OK)

WARN-NEW: Absence of Anti-CSRF Tokens [10202] x 2

http://host.docker.internal:8000/taskManager/forgot_password/ (200 OK)

http://host.docker.internal:8000/taskManager/forgot_password/ (500 Internal Server Error)

WARN-NEW: Private IP Disclosure [2] x 1

http://host.docker.internal:8000/taskManager/forgot_password/ (500 Internal Server Error)

WARN-NEW: Sub Resource Integrity Attribute Missing [90003] x 5

http://host.docker.internal:8000 (200 OK)

http://host.docker.internal:8000 (200 OK)

http://host.docker.internal:8000 (200 OK)

http://host.docker.internal:8000/ (200 OK)

http://host.docker.internal:8000/ (200 OK)

WARN-NEW: Cross-Origin-Embedder-Policy Header Missing or Invalid [90004] x 11

http://host.docker.internal:8000 (200 OK)

http://host.docker.internal:8000/ (200 OK)

http://host.docker.internal:8000/taskManager/tutorials/ (200 OK)

http://host.docker.internal:8000 (200 OK)

http://host.docker.internal:8000/ (200 OK)

WARN-NEW: Application Error Disclosure [90022] x 1

http://host.docker.internal:8000/taskManager/forgot_password/ (500 Internal Server Error)

FAIL-NEW: 0 FAIL-INPROG: 0 WARN-NEW: 19 WARN-INPROG: 0 INFO: 0 IGNORE: 0 PASS: 48

django.nV %

```

```

```
(base) sapman@Mac-mini-sapman django.nV % docker run --rm -u root -v "$(pwd):/zap/wrk/:rw" -t zaproxy/zap-stable zap-baseline.py -t http://host.docker.internal:8000 -J zap-report.json -x zap-report
.xml
Unable to find image 'zaproxy/zap-stable:latest' locally
latest: Pulling from zaproxy/zap-stable
1dbbb2db815c: Pull complete
c8d09c37986b: Pull complete
5d9591fe0849: Pull complete
1f5d3138364a: Pull complete
c7bcd7545dc2: Pull complete
6cc5f8166a8f: Pull complete
4f4fb700ef54: Pull complete
e039cda8c112: Pull complete
0631a84110d1: Pull complete
c1f54caee7ee: Pull complete
546e225bbd21: Pull complete
6e84b9e21399: Pull complete
79930899c92e: Pull complete
90d22e91690c: Pull complete
d5e29918fb24: Pull complete
22f5576fdcda: Pull complete
69d986feefc5: Pull complete
fd9f6600bc27: Pull complete
c4c056a77532: Pull complete
4b362275d971: Pull complete
Digest: sha256:707fc6b9fd8327ba48bb7b49d0c5732c179b045dab9c99f8b95410627dff4a00
Status: Downloaded newer image for zaproxy/zap-stable:latest
Using the Automation Framework
Total of 63 URLs
PASS: In Page Banner Information Leak [10009]
PASS: Cookie Without Secure Flag [10011]
PASS: Re-examine Cache-control Directives [10015]
PASS: Content-Type Header Missing [10019]
PASS: Anti-clickjacking Header [10020]
PASS: Information Disclosure - Debug Error Messages [10023]
PASS: Information Disclosure - Sensitive Information in URL [10024]
PASS: Information Disclosure - Sensitive Information in HTTP Referrer Header [10025]
PASS: HTTP Parameter Override [10026]
PASS: Off-site Redirect [10028]
PASS: Cookie Poisoning [10029]
PASS: User Controllable Charset [10030]
PASS: User Controllable HTML Element Attribute (Potential XSS) [10031]
PASS: Viewstate [10032]
PASS: Directory Browsing [10033]
PASS: Heartbleed OpenSSL Vulnerability (Indicative) [10034]
PASS: Strict-Transport-Security Header [10035]
PASS: Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s) [10037]
PASS: X-Backend-Server Header Information Leak [10039]
PASS: Secure Pages Include Mixed Content [10040]
PASS: HTTP to HTTPS Insecure Transition in Form Post [10041]
PASS: HTTPS to HTTP Insecure Transition in Form Post [10042]
PASS: User Controllable JavaScript Event (XSS) [10043]
PASS: Big Redirect Detected (Potential Sensitive Information Leak) [10044]
PASS: Retrieved from Cache [10050]
PASS: X-ChromeLogger-Data (XCOLD) Header Information Leak [10052]
PASS: CSP [10055]
PASS: X-Debug-Token Information Leak [10056]
PASS: Username Hash Found [10057]
PASS: X-AspNet-Version Response Header [10061]
PASS: PII Disclosure [10062]
PASS: Timestamp Disclosure [10096]
PASS: Hash Disclosure [10097]
PASS: Cross-Domain Misconfiguration [10098]
PASS: Weak Authentication Method [10105]
PASS: Reverse Tabnabbing [10108]
PASS: Dangerous JS Functions [10110]
PASS: Verification Request Identified [10113]
PASS: Script Served From Malicious Domain (polyfill) [10115]
PASS: ZAP is Out of Date [10116]
PASS: Session ID in URL Rewrite [3]
PASS: Script Passive Scan Rules [50001]
PASS: Stats Passive Scan Rule [50003]
PASS: Insecure JSF ViewState [90001]
PASS: Java Serialization Object [90002]
PASS: Charset Mismatch [90011]
PASS: WSDL File Detection [90030]
PASS: Loosely Scoped Cookie [90033]
```

```
PASS: WSDL File Detection [90030]
PASS: Loosely Scoped Cookie [90033]
WARN-NEW: Vulnerable JS Library [10003] x 2
        http://host.docker.internal:8000/static/taskManager/js/bootstrap.js (200 OK)
        http://host.docker.internal:8000/static/taskManager/js/jquery-1.8.3.min.js (200 OK)
WARN-NEW: Cookie No HttpOnly Flag [10010] x 2
        http://host.docker.internal:8000/taskManager/login/ (200 OK)
        http://host.docker.internal:8000/taskManager/register/ (200 OK)
WARN-NEW: Cross-Domain JavaScript Source File Inclusion [10017] x 5
        http://host.docker.internal:8000 (200 OK)
        http://host.docker.internal:8000/ (200 OK)
        http://host.docker.internal:8000/taskManager/ (200 OK)
        http://host.docker.internal:8000/taskManager/register/ (200 OK)
        http://host.docker.internal:8000/taskManager/tutorials/ (200 OK)
WARN-NEW: X-Content-Type-Options Header Missing [10021] x 5
        http://host.docker.internal:8000 (200 OK)
        http://host.docker.internal:8000/ (200 OK)
        http://host.docker.internal:8000/static/taskManager/css/bootstrap.min.css (200 OK)
        http://host.docker.internal:8000/static/taskManager/css/font-awesome.css (200 OK)
        http://host.docker.internal:8000/taskManager/tutorials/ (200 OK)
WARN-NEW: Information Disclosure - Suspicious Comments [10027] x 12
        http://host.docker.internal:8000/taskManager/register/ (200 OK)
        http://host.docker.internal:8000/taskManager/tutorials/ (200 OK)
        http://host.docker.internal:8000/taskManager/tutorials/access/ (200 OK)
        http://host.docker.internal:8000/taskManager/tutorials/brokenauth/ (200 OK)
        http://host.docker.internal:8000/taskManager/tutorials/components/ (200 OK)
WARN-NEW: Server Leaks Version Information via "Server" HTTP Response Header Field [10036] x 5
        http://host.docker.internal:8000 (200 OK)
        http://host.docker.internal:8000/ (200 OK)
        http://host.docker.internal:8000/robots.txt (404 Not Found)
        http://host.docker.internal:8000/sitemap.xml (404 Not Found)
        http://host.docker.internal:8000/taskManager/register (301 Moved Permanently)
WARN-NEW: Content Security Policy (CSP) Header Not Set [10038] x 2
        http://host.docker.internal:8000 (200 OK)
        http://host.docker.internal:8000/ (200 OK)
WARN-NEW: Storable and Cacheable Content [10049] x 5
        http://host.docker.internal:8000 (200 OK)
        http://host.docker.internal:8000/robots.txt (404 Not Found)
        http://host.docker.internal:8000/sitemap.xml (404 Not Found)
        http://host.docker.internal:8000/static/taskManager/css/bootstrap.min.css (200 OK)
        http://host.docker.internal:8000/taskManager/tutorials/ (200 OK)
WARN-NEW: Cookie without SameSite Attribute [10054] x 2
        http://host.docker.internal:8000/taskManager/login/ (200 OK)
        http://host.docker.internal:8000/taskManager/register/ (200 OK)
WARN-NEW: Permissions Policy Header Not Set [10063] x 5
        http://host.docker.internal:8000 (200 OK)
        http://host.docker.internal:8000/ (200 OK)
        http://host.docker.internal:8000/robots.txt (404 Not Found)
        http://host.docker.internal:8000/sitemap.xml (404 Not Found)
        http://host.docker.internal:8000/taskManager/tutorials/ (200 OK)
WARN-NEW: Source Code Disclosure - SQL [10099] x 1
        http://host.docker.internal:8000/taskManager/tutorials/injection/ (200 OK)
WARN-NEW: Modern Web Application [10109] x 1
        http://host.docker.internal:8000/taskManager/forgot_password/ (500 Internal Server Error)
WARN-NEW: Authentication Request Identified [10111] x 1
        http://host.docker.internal:8000/taskManager/login/ (403 Forbidden)
WARN-NEW: Session Management Response Identified [10112] x 2
        http://host.docker.internal:8000/taskManager/login/ (200 OK)
        http://host.docker.internal:8000/taskManager/register/ (200 OK)
WARN-NEW: Absence of Anti-CSRF Tokens [10202] x 2
        http://host.docker.internal:8000/taskManager/forgot_password/ (200 OK)
        http://host.docker.internal:8000/taskManager/forgot_password/ (500 Internal Server Error)
WARN-NEW: Private IP Disclosure [2] x 1
        http://host.docker.internal:8000/taskManager/forgot_password/ (500 Internal Server Error)
WARN-NEW: Sub Resource Integrity Attribute Missing [90003] x 5
        http://host.docker.internal:8000 (200 OK)
        http://host.docker.internal:8000 (200 OK)
        http://host.docker.internal:8000 (200 OK)
        http://host.docker.internal:8000/ (200 OK)
        http://host.docker.internal:8000/ (200 OK)
WARN-NEW: Cross-Origin-Embedder-Policy Header Missing or Invalid [90004] x 11
        http://host.docker.internal:8000 (200 OK)
        http://host.docker.internal:8000/ (200 OK)
        http://host.docker.internal:8000/taskManager/tutorials/ (200 OK)
        http://host.docker.internal:8000 (200 OK)
        http://host.docker.internal:8000/ (200 OK)
WARN-NEW: Application Error Disclosure [90022] x 1
        http://host.docker.internal:8000/taskManager/forgot_password/ (500 Internal Server Error)
FAIL-NEW: 0     FAIL-INPROG: 0  WARN-NEW: 19    WARN-INPROG: 0  INFO: 0 IGNORE: 0       PASS: 48
(base) sapman@Mac-mini-sapman django.nV %
```

Проверка структуры локальной копии репо:

```
(base) sapman@Mac-mini-sapman django.nV %
(base) sapman@Mac-mini-sapman django.nV % ls -la
total 1440
drwxr-xr-x  30 sapman  staff     960 21 апр.  18:20 .
drwxr-xr-x@  5 sapman  staff     160 20 апр.  22:42 ..
-rw-r--r--@  1 sapman  staff   10244 20 апр.  23:55 .DS_Store
drwxr-xr-x  15 sapman  staff     480  1 апр.  18:33 .git
-rw-r--r--   1 sapman  staff     652 30 марта 11:42 .gitignore
-rw-r--r--@  1 sapman  staff   22014 20 апр.  23:59 bandit-docker-report.json
-rw-r--r--   1 sapman  staff   22014 21 апр.  00:01 bandit-report-docker.json
-rw-r--r--@  1 sapman  staff   22014 21 апр.  00:03 bandit-report.json
-rw-r--r--   1 sapman  staff  200704 21 апр.  18:20 db.sqlite3
-rw-r--r--   1 sapman  staff      56 30 марта 12:44 fake_secret.txt
drwxr-xr-x   7 sapman  staff     224 30 марта 11:42 fixtures
-rw-r--r--   1 sapman  staff     207 30 марта 13:33 gitleaks-custom.toml
-rw-r--r--@  1 sapman  staff     916 30 марта 13:47 gitleaks-extended.toml
-rw-r--r--@  1 sapman  staff     916 30 марта 13:47 gitleaks-orig.toml
-rw-r--r--@  1 sapman  staff    4605 30 марта 23:15 gitleaks-report.json
-rw-r--r--   1 sapman  staff   18046 30 марта 11:42 LICENSE.md
-rw-r--r--   1 sapman  staff     689 30 марта 11:42 manage.py
-rw-r--r--   1 sapman  staff    2414 30 марта 11:42 README.md
-rw-r--r--   1 sapman  staff      14 30 марта 11:42 requirements.txt
-rwxr-xr-x   1 sapman  staff     101 30 марта 11:42 reset_db.sh
-rwxr-xr-x   1 sapman  staff      39 30 марта 11:42 runapp.sh
drwxr-xr-x  17 sapman  staff     544 21 апр.  18:11 taskManager
-rw-r--r--   1 sapman  staff   85063  1 апр.  18:29 trivy-docker-report.json
-rw-r--r--   1 sapman  staff   85062  1 апр.  18:15 trivy-report.json
-rw-r--r--@  1 sapman  staff     129 30 марта 17:01 trufflehog-config.yaml
-rw-r--r--   1 sapman  staff    2514 30 марта 17:01 trufflehog-report.json
-rw-r--r--@  1 sapman  staff     877 30 марта 14:14 trufflehog-rules.json
-rw-r--r--   1 sapman  staff   61292 21 апр.  18:20 zap-report.json
-rw-r--r--   1 sapman  staff   73105 21 апр.  18:20 zap-report.xml
-rw-r--r--   1 sapman  staff     875 21 апр.  18:19 zap.yaml
(base) sapman@Mac-mini-sapman django.nV %
```

GitLab CI

Необходимо убедиться в том, что локальный докер приложения запущен.

В случае если контейнер остановлен, повторить запуск из пункта [Запуск в контейнере]

Содержимое файла пайплайна:

```bash
# -----------------------------------------------------
# STAGES
# -----------------------------------------------------
stages:
  - build
  - test
  - prod
```

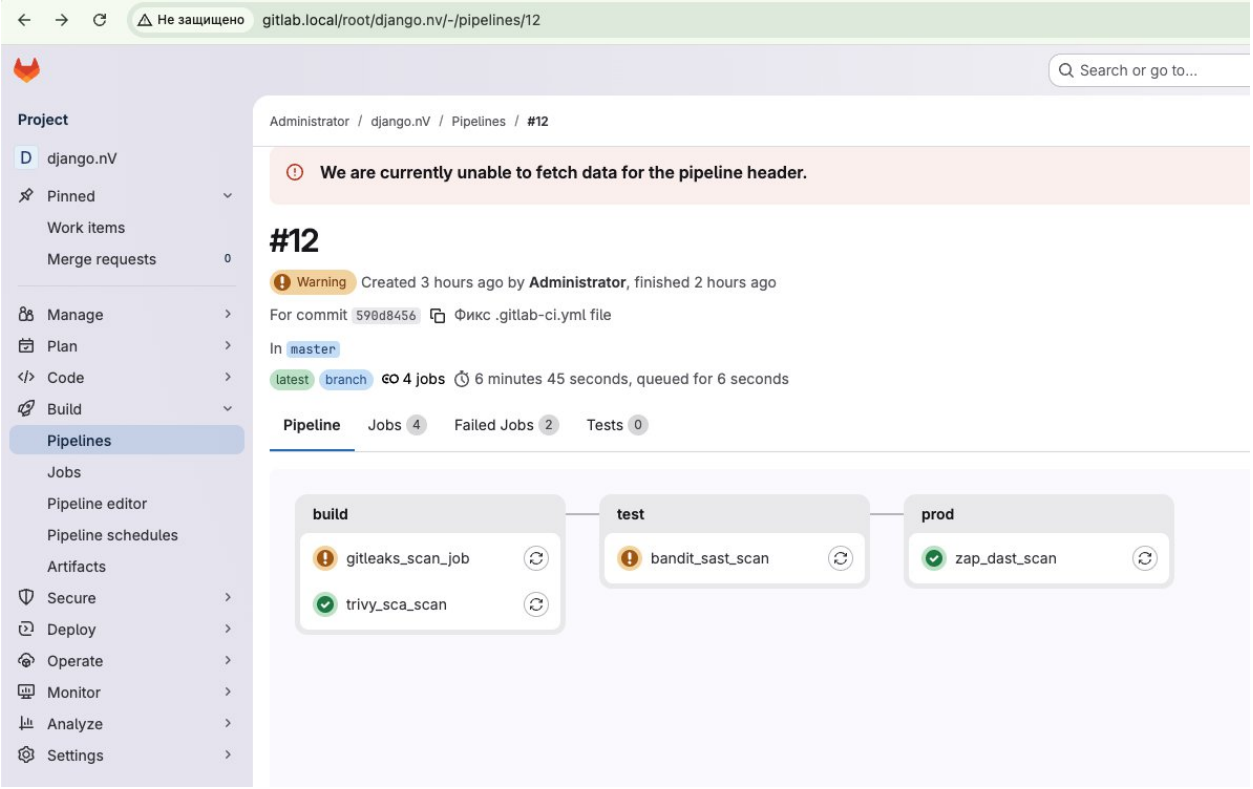
```yaml
# ----------------------------------------------------------
# STAGE: BUILD (SCA)
# ----------------------------------------------------------


gitleaks_scan_job:
  stage: build
  tags:
    - shared
  image:
    name: zricethezav/gitleaks:latest
    entrypoint: [""]
  script:
    - echo "Сканирования Secret Detection by Gitleaks..."
    - gitleaks detect --no-git -v --config gitleaks-orig.toml --report-format json --report-path gitleaks-report.json
  artifacts:
    paths:
      - gitleaks-report.json
    when: always
    expire_in: 1 week
  allow_failure: true

trivy_sca_scan:
  stage: build
  image:
    name: aquasec/trivy:latest
    entrypoint: [""]
  script:
    - echo "Запуск SCA-сканирования через Trivy..."
    - trivy fs . --format json --output trivy-report.json
  # Продолжаеть работу пайплайна при нахождении уязвимостей (требование к заданию)
  allow_failure: true
  artifacts:
    paths:
```

```
      - trivy-report.json
    # Сохраняет артефакт всегда (требование к заданию)
    when: always
    expire_in: 1 week

# ------------------------------------------------------------
# STAGE: TEST (SAST)
# ------------------------------------------------------------
bandit_sast_scan:
  stage: test
  image: python:3.10-slim
  script:
    - echo "Установка и запуск SAST-сканера Bandit..."
    - pip install --quiet bandit
    # Флаг -ll фильтрует уязвимости (оставляет только от Medium и выше)
    # Флаг -r запускает рекурсивный поиск по директории
    - bandit -r . -ll -f json -o bandit-report.json
  allow_failure: true
  artifacts:
    paths:
      - bandit-report.json
    when: always
    expire_in: 1 week

# ------------------------------------------------------------
# STAGE: PROD (DAST)
# ------------------------------------------------------------
zap_dast_scan:
  stage: prod
  image:
    name: zaproxy/zap-stable
    entrypoint: [""]
  script:
    - echo "Начало DAST используя OWASP ZAP..."
    - mkdir -p /zap/wrk
    - chmod 777 /zap/wrk
```

```
  - find /zap -name "*.py" -exec sed -i 's/os.path.ismount/os.path.isdir/g' {} +
  - zap-baseline.py -t http://host.docker.internal:8000 -x zap-report.xml || true
  - cp /zap/wrk/zap-report.xml .
  - echo "!!!Сканирование на безопасность проведено!!!"
  - echo "Отчёты в артифактах"
  - echo "Место для вашей рекламы..."
allow_failure: true
artifacts:
  paths:
    - zap-report.xml
  when: always
  expire_in: 1 week
```

Скрины с выполнением шагов.

Намеренно оставил шаг «gitleaks_scan_job» из предыдущего задания для более детального понимания процесса.



Search or go to... / 0 0 0 Admin

Project
D django.nV
Pinned
Work items
Merge requests 0
Manage
Plan
Code
Build
Pipelines
Jobs
Pipeline editor
Pipeline schedules
Artifacts
Secure
Deploy
Operate
Monitor
Analyze
Settings

Administrator / django.nV / Pipelines / #12

We are currently unable to fetch data for the pipeline header.

#12

Retry Delete

Warning Created 3 hours ago by **Administrator**, finished 2 hours ago

For commit `590d8456` Фикс .gitlab-ci.yml file

In `master`

latest branch 4 jobs 6 minutes 45 seconds, queued for 6 seconds

Pipeline | Jobs 4 | Failed Jobs 2 | Tests 0

Status	Job	Stage	Coverage
Passed 00:02:47 2 hours ago	#39: zap_dast_scan master 590d8456	prod	
Failed 00:01:03 2 hours ago	#38: bandit_sast_scan master 590d8456 allowed to fail	test	
Passed 00:01:40 2 hours ago	#37: trivy_sca_scan master 590d8456	build	
Failed 00:01:14 2 hours ago	#36: gitleaks_scan_job master 590d8456 shared allowed to fail	build	

Не защищено gitlab.local/root/django.nV/-/jobs/39

Search or go to...

Project
D django.nV
Pinned
Work items
Merge requests 0
Manage
Plan
Code
Build
Pipelines
Jobs
Pipeline editor
Pipeline schedules
Artifacts
Secure
Deploy
Operate
Monitor
Analyze
Settings
What's new 5
Help

Administrator / django.nV / Jobs / #39

Log timestamps in UTC.

```
134 15:59:35          http://host.docker.internal:8000/taskManager/register/ (200 OK)
135 15:59:35 WARN-NEW: Permissions Policy Header Not Set [10063] x 5
136 15:59:35          http://host.docker.internal:8000 (200 OK)
137 15:59:35          http://host.docker.internal:8000/ (200 OK)
138 15:59:35          http://host.docker.internal:8000/robots.txt (404 Not Found)
139 15:59:35          http://host.docker.internal:8000/sitemap.xml (404 Not Found)
140 15:59:35          http://host.docker.internal:8000/taskManager/ (200 OK)
141 15:59:35 WARN-NEW: Source Code Disclosure - SQL [10099] x 1
142 15:59:35          http://host.docker.internal:8000/taskManager/tutorials/injection/ (200 OK)
143 15:59:35 WARN-NEW: Modern Web Application [10109] x 1
144 15:59:35          http://host.docker.internal:8000/taskManager/forgot_password/ (500 Internal Server Error)
145 15:59:35 WARN-NEW: Authentication Request Identified [10111] x 1
146 15:59:35          http://host.docker.internal:8000/taskManager/login/ (403 Forbidden)
147 15:59:35 WARN-NEW: Session Management Response Identified [10112] x 3
148 15:59:35          http://host.docker.internal:8000/taskManager/login/ (200 OK)
149 15:59:35          http://host.docker.internal:8000/taskManager/register/ (200 OK)
150 15:59:35          http://host.docker.internal:8000/taskManager/register/ (200 OK)
151 15:59:35 WARN-NEW: Absence of Anti-CSRF Tokens [10202] x 2
152 15:59:35          http://host.docker.internal:8000/taskManager/forgot_password/ (200 OK)
153 15:59:35          http://host.docker.internal:8000/taskManager/forgot_password/ (500 Internal Server Error)
154 15:59:35 WARN-NEW: Private IP Disclosure [2] x 1
155 15:59:35          http://host.docker.internal:8000/taskManager/forgot_password/ (500 Internal Server Error)
156 15:59:35 WARN-NEW: Sub Resource Integrity Attribute Missing [90003] x 5
157 15:59:35          http://host.docker.internal:8000 (200 OK)
158 15:59:35          http://host.docker.internal:8000 (200 OK)
159 15:59:35          http://host.docker.internal:8000 (200 OK)
160 15:59:35          http://host.docker.internal:8000/ (200 OK)
161 15:59:35          http://host.docker.internal:8000/ (200 OK)
162 15:59:35 WARN-NEW: Cross-Origin-Embedder-Policy Header Missing or Invalid [90004] x 9
163 15:59:35          http://host.docker.internal:8000 (200 OK)
164 15:59:35          http://host.docker.internal:8000/ (200 OK)
165 15:59:35          http://host.docker.internal:8000/taskManager/ (200 OK)
166 15:59:35          http://host.docker.internal:8000 (200 OK)
167 15:59:35          http://host.docker.internal:8000/ (200 OK)
168 15:59:35 WARN-NEW: Application Error Disclosure [90022] x 1
169 15:59:35          http://host.docker.internal:8000/taskManager/forgot_password/ (500 Internal Server Error)
170 15:59:35 FAIL-NEW: 0     FAIL-INPROG: 0  WARN-NEW: 21    WARN-INPROG: 0  INFO: 0 IGNORE: 0       PASS: 46
171 15:59:36 $ cp /zap/wrk/zap-report.xml .
172 15:59:36 $ echo "!!!Сканирование на безопасность проведено!!!"
173 15:59:36 !!!Сканирование на безопасность проведено!!!
174 15:59:36 $ echo "Отчёты в артифактах"
175 15:59:36 Отчёты в артифактах
176 15:59:36 $ echo "Место для вашей рекламы..."
177 15:59:36 Место для вашей рекламы...
178 15:59:37 Uploading artifacts for successful job
179 15:59:38 Uploading artifacts...
180 15:59:38 zap-report.xml: found 1 matching artifact files and directories
181 15:59:51 Uploading artifacts as "archive" to coordinator... 201 Created  correlation_id=01KPTYPHPT7V5NNYY9S1E7QZEY id=39 responseStatus=201 Created token=64_PQJ9y9
182 15:59:51 Cleaning up project directory and file based variables
183 15:59:52 Job succeeded
```

VMS. Опциональная часть

Необходимо убедиться в том, что локальный докер приложения запущен.

В случае если контейнер остановлен, повторить запуск из пункта [Запуск в контейнере]

Убраны не требуемые инструменты из пайпа дабы избежать лишних ошибок.

Содержимое файла пайплайна «dojo_upload.py» для выгрузки отчёта в dojo:

```py
import requests
import sys
import os

# ENVs
DOJO_URL = os.getenv("DEFECTDOJO_URL", "http://localhost:8080")
API_KEY = os.getenv("DEFECTDOJO_API_KEY")
PRODUCT_ID = os.getenv("DEFECTDOJO_PRODUCT_ID")
ENGAGEMENT_ID = os.getenv("DEFECTDOJO_ENGAGEMENT_ID")

def upload_to_dojo(file_path, scan_type):
    if not API_KEY:
        print("[ERROR] DEFECTDOJO_API_KEY is not set")
        return
    import_url = f"{DOJO_URL.rstrip('/')}/api/v2/import-scan/"
    headers = {
        "Authorization": f"Token {API_KEY}"
    }
    # Параметры загрузки
    data = {
        "engagement": ENGAGEMENT_ID,
        "scan_type": scan_type,
        "active": True,
        "verified": True,
        "close_old_findings": True,
        "push_to_jira": False
    }
```

```
    try:
        with open(file_path, "rb") as f:
            files = {"file": f}
            response = requests.post(import_url, headers=headers, data=data, files=files)
        if response.status_code in [200, 201]:
            print(f"[SUCCESS] {scan_type} report uploaded successfully!")
        else:
            print(f"[ERROR] Failed to upload {scan_type}. Status: {response.status_code}")
            print(response.text)
    except FileNotFoundError:
        print(f"[ERROR] File not found: {file_path}")
if __name__ == "__main__":
    if len(sys.argv) < 3:
        print("Usage: python dojo_upload.py <file_path> <scan_type>")
    else:
        upload_to_dojo(sys.argv[1], sys.argv[2])
```

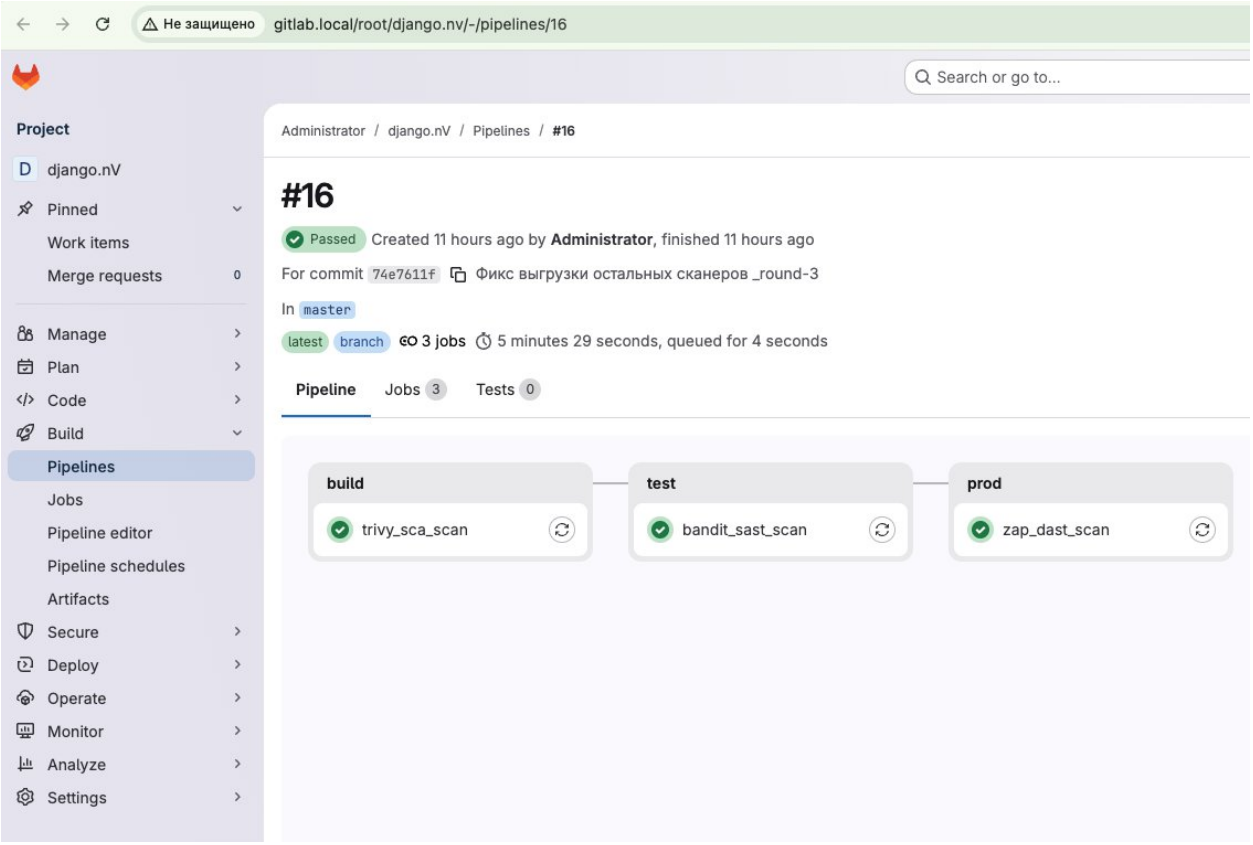
Содержимое файла пайплайна «.gitlab-ci.yml»:

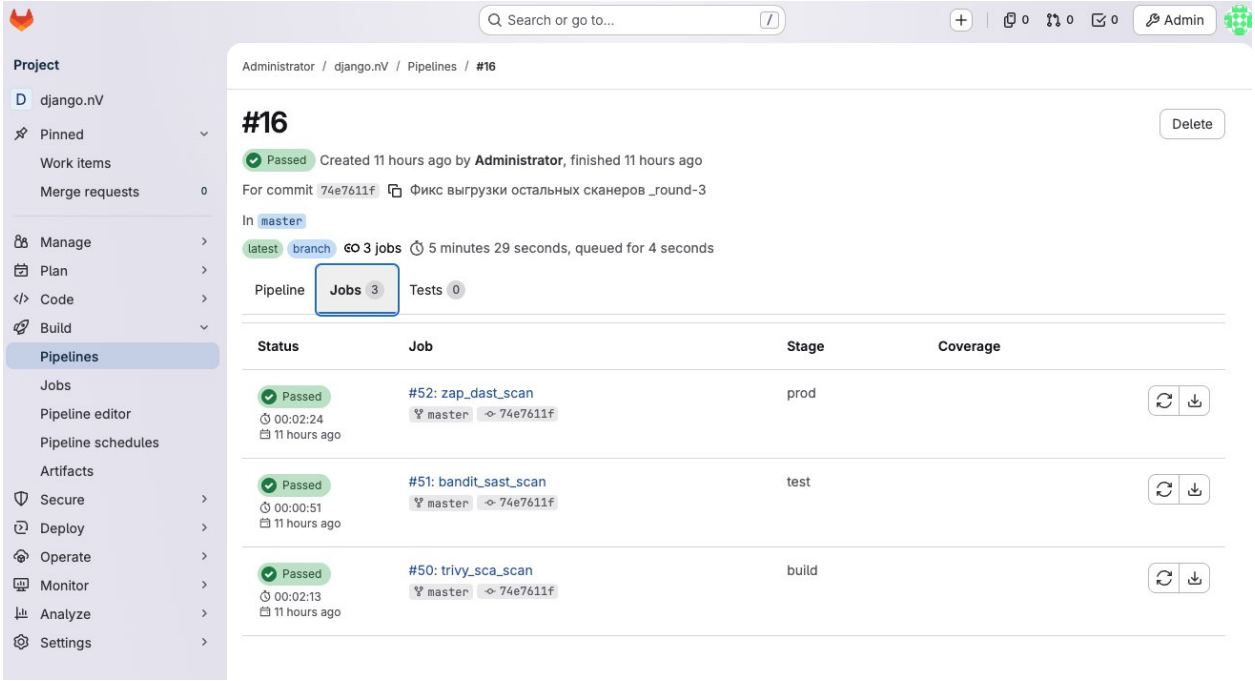
```bash
# ---------------------------------------------------------
# STAGES
# ---------------------------------------------------------
stages:
  - build
  - test
  - prod

# ---------------------------------------------------------
# STAGE: BUILD (SCA - GitLeaks + Trivy)
# ---------------------------------------------------------
# gitleaks_scan_job:
#   stage: build
#   tags:
```

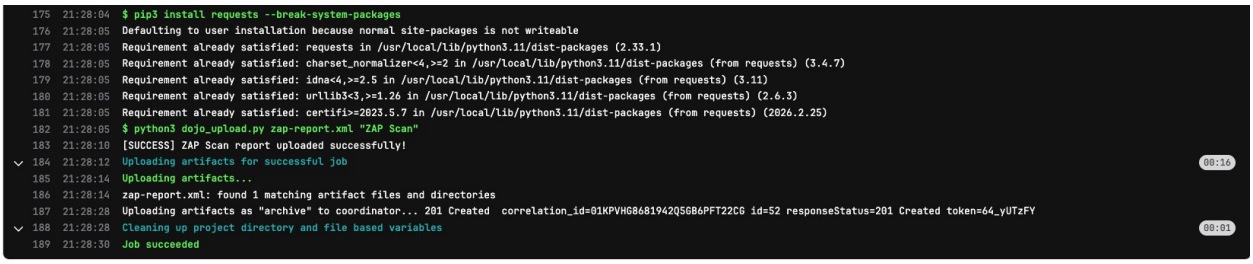
```
#     - shared
#   image:
#     name: zricethezav/gitleaks:latest
#     entrypoint: [""]
#   script:
#     - echo "Сканирования Secret Detection by Gitleaks..."
#     - gitleaks detect --no-git -v --config gitleaks-orig.toml --report-format json --report-path gitleaks-report.json
#   artifacts:
#     paths:
#       - gitleaks-report.json
#     when: always
#     expire_in: 1 week
#   allow_failure: true

trivy_sca_scan:
  stage: build
  image:
    name: aquasec/trivy:latest
    entrypoint: [""]
  script:
    - echo "Запуск SCA-сканирования через Trivy..."
    - apk add --no-cache python3 py3-requests
    - trivy fs . --format json --output trivy-report.json || true
    # Имя сканера "Trivy Scan"
    - python3 dojo_upload.py trivy-report.json "Trivy Scan"
  # Продолжаеть работу пайплайна при нахождении уязвимостей (требование к заданию)
  allow_failure: true
  artifacts:
    paths:
      - trivy-report.json
    # Сохраняет артефакт всегда (требование к заданию)
    when: always
    expire_in: 1 week

# ----------------------------------------------------------
# STAGE: TEST (SAST - Bandid)
```

```yaml
# -------------------------------------------------------
bandit_sast_scan:
  stage: test
  image: python:3.10-slim
  script:
    - echo "Установка и запуск SAST-сканера Bandit..."
    - pip install --quiet bandit requests --break-system-packages || pip install --quiet bandit requests
    - bandit -r . -ll -f json -o bandit-report.json || true
    # Имя сканера "Bandit Scan"
    - python3 dojo_upload.py bandit-report.json "Bandit Scan"
  allow_failure: true
  artifacts:
    paths:
      - bandit-report.json
    when: always
    expire_in: 1 week

# -------------------------------------------------------
# STAGE: PROD (DAST - Zap + Dojo)
# -------------------------------------------------------
zap_dast_scan:
  stage: prod
  image:
    name: zaproxy/zap-stable
    entrypoint: [""]
  script:
    - echo "Начинаем динамическое сканирование (DAST) через OWASP ZAP..."
    - mkdir -p /zap/wrk
    - chmod 777 /zap/wrk
    - find /zap -name "*.py" -exec sed -i 's/os.path.ismount/os.path.isdir/g' {} +

    # Запуск сканера
    - zap-baseline.py -t http://host.docker.internal:8000 -x zap-report.xml || true
    - cp /zap/wrk/zap-report.xml .
```

```
  # Минутка комментов
  - echo "!!!Сканирование на безопасность проведено!!!"
  - echo "Отчёты в артифактах"
  - echo "Место для вашей рекламы..."

  # Ставим переменные через requests
  - pip3 install requests --break-system-packages

  # Выгрузка XML-отчета в DefectDojo
  - python3 dojo_upload.py zap-report.xml "ZAP Scan"


allow_failure: true
artifacts:
  paths:
    - zap-report.xml
  when: always
  expire_in: 1 week
```







Отображение с отправленными инструментами из Engagement

localhost:8080/engagement/1

DEFECTDOJO

Search...

- Dashboard
- Products
- Engagements
- Findings
- Finding Groups
- Components
- Endpoints
- Reports
- Metrics
- Users
- Calendar
- Questionnaires
- Configuration
- Upgrade
- Collapse Menu

django.nv

Overview | Components | Metrics | Engagements 1 | Findings 70 | Hosts / Endpoints 1 / 26 | Benchmarks | Settings

Engagements / GitLab CI Scans / View Engagement

Description

GitLab CI Scans

Tests (4) Critical: 5, High: 5, Medium: 22, Low: 24, Info: 14, Total: 70 Active Findings

Showing entries 1 to 4 of 4

Page Size

Title / Type	Date	Lead	Total Findings	Active (Verified / Fixable)	Mitigated	Duplicates	Notes	Reimports
Bandit Scan	April 22, 2026 - April 22, 2026		3	3 (3 / 0)	0	0		0
Trivy Scan	April 22, 2026 - April 22, 2026		21	21 (21 / 21)	0	0		0
ZAP Scan	April 22, 2026 - April 22, 2026		23	23 (23 / 0)	0	0		0
ZAP Scan	April 22, 2026 - April 22, 2026		23	23 (23 / 0)	0	0		0

Showing entries 1 to 4 of 4

Page Size

Risk Acceptance

No Risk Acceptances found.

Additional Features

ProTip! Type e to edit this engagement. Type i to import scan results or a to add tests.

GitLab CI Scans

Status	*Not Started*
Dates	22nd April - 29th April
Length	7 days
Lead	Admin User (admin)
Tracker	*Not Specified*
Repo	*Not Specified*
Test Strategy	*Not Specified*
Updated	11 hours ago
Created	12 hours ago

Credentials

Name		Userna

*No Credentials Configured for this **Product***

DEFECTDOJO

Search... 11

- Dashboard
- Products
- Engagements
- Findings
- Finding Groups
- Components
- Endpoints
- Reports
- Metrics
- Users
- Calendar
- Questionnaires
- Configuration
- Upgrade
- Collapse Menu

django.nv

Overview | Components | Metrics | Engagements 1 | Findings 70 | Hosts / Endpoints 1 / 26 | Benchmarks | Settings

Description

django.nv

Metrics

5	5	22	24	14	70
CRITICAL	HIGH	MEDIUM	LOW	INFORMATIONAL	TOTAL

Technologies

There are no technologies.

Regulations

There are no regulations.

Benchmark Progress

There are no benchmarks

Members

User	Source	Role
Admin User (admin)	Product Type: Research and Development	Owner

Groups

No groups found.

Metadata

Business Criticality	*Not Specified*
Product Type	Research and Development
Platform	*Not Specified*
Lifecycle	*Not Specified*
Origin	*Not Specified*
User Records	*Not Specified*
Revenue	*Not Specified*

Service Level Agreement

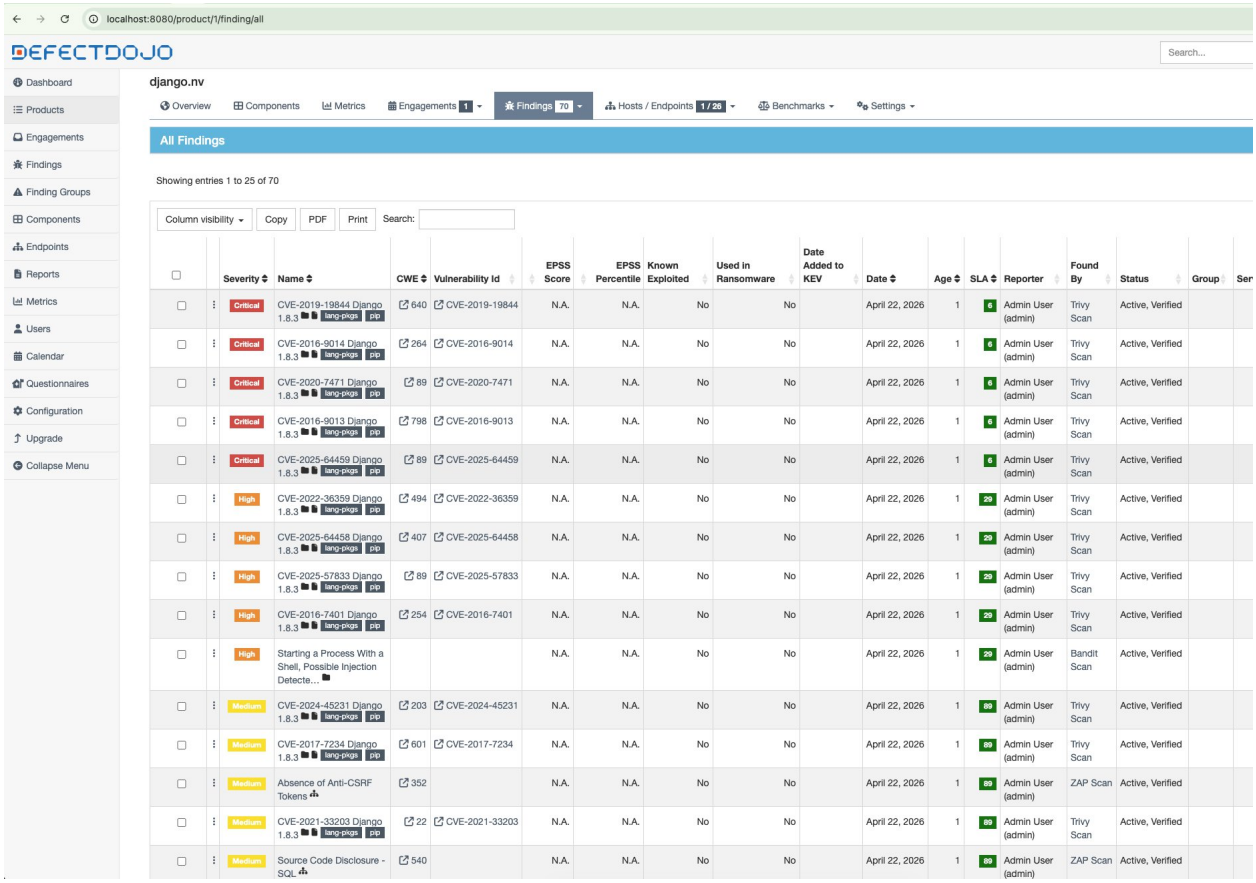
Default

The Default SLA Configuration. Products not using an explicit SLA Configuration will use th one.

Critical	7 days to remediate
High	30 days to remediate
Medium	90 days to remediate
Low	120 days to remediate

Contacts

Team Manager	Unknown
Product Manager	Unknown
Technical Contact	Unknown



Severity	Name	CWE	Vulnerability Id	EPSS Score	EPSS Percentile	Known Exploited	Used in Ransomware	Date Added to KEV	Date	Age	SLA	Reporter	Found By	Status	Group
Critical	CVE-2019-19844 Django 1.8.3 lang-pkgs pip	640	CVE-2019-19844	N.A.	N.A.	No	No		April 22, 2026	1	6	Admin User (admin)	Trivy Scan	Active, Verified	
Critical	CVE-2016-9014 Django 1.8.3 lang-pkgs pip	264	CVE-2016-9014	N.A.	N.A.	No	No		April 22, 2026	1	6	Admin User (admin)	Trivy Scan	Active, Verified	
Critical	CVE-2020-7471 Django 1.8.3 lang-pkgs pip	89	CVE-2020-7471	N.A.	N.A.	No	No		April 22, 2026	1	6	Admin User (admin)	Trivy Scan	Active, Verified	
Critical	CVE-2016-9013 Django 1.8.3 lang-pkgs pip	798	CVE-2016-9013	N.A.	N.A.	No	No		April 22, 2026	1	6	Admin User (admin)	Trivy Scan	Active, Verified	
Critical	CVE-2025-64459 Django 1.8.3 lang-pkgs pip	89	CVE-2025-64459	N.A.	N.A.	No	No		April 22, 2026	1	6	Admin User (admin)	Trivy Scan	Active, Verified	
High	CVE-2022-36359 Django 1.8.3 lang-pkgs pip	494	CVE-2022-36359	N.A.	N.A.	No	No		April 22, 2026	1	29	Admin User (admin)	Trivy Scan	Active, Verified	
High	CVE-2025-64458 Django 1.8.3 lang-pkgs pip	407	CVE-2025-64458	N.A.	N.A.	No	No		April 22, 2026	1	29	Admin User (admin)	Trivy Scan	Active, Verified	
High	CVE-2025-57833 Django 1.8.3 lang-pkgs pip	89	CVE-2025-57833	N.A.	N.A.	No	No		April 22, 2026	1	29	Admin User (admin)	Trivy Scan	Active, Verified	
High	CVE-2016-7401 Django 1.8.3 lang-pkgs pip	254	CVE-2016-7401	N.A.	N.A.	No	No		April 22, 2026	1	29	Admin User (admin)	Trivy Scan	Active, Verified	
High	Starting a Process With a Shell, Possible Injection Detecte...			N.A.	N.A.	No	No		April 22, 2026	1	29	Admin User (admin)	Bandit Scan	Active, Verified	
Medium	CVE-2024-45231 Django 1.8.3 lang-pkgs pip	203	CVE-2024-45231	N.A.	N.A.	No	No		April 22, 2026	1	89	Admin User (admin)	Trivy Scan	Active, Verified	
Medium	CVE-2017-7234 Django 1.8.3 lang-pkgs pip	601	CVE-2017-7234	N.A.	N.A.	No	No		April 22, 2026	1	89	Admin User (admin)	Trivy Scan	Active, Verified	
Medium	Absence of Anti-CSRF Tokens	352		N.A.	N.A.	No	No		April 22, 2026	1	89	Admin User (admin)	ZAP Scan	Active, Verified	
Medium	CVE-2021-33203 Django 1.8.3 lang-pkgs pip	22	CVE-2021-33203	N.A.	N.A.	No	No		April 22, 2026	1	89	Admin User (admin)	Trivy Scan	Active, Verified	
Medium	Source Code Disclosure - SQL	540		N.A.	N.A.	No	No		April 22, 2026	1	89	Admin User (admin)	ZAP Scan	Active, Verified	

Дополнительная информация

Все коммиты можно найти в личном пространстве

https://github.com/sapsolman/netology-hse/blob/main/2026.04.09/README.md